KiKi Pentester - Security Report

Executive Summary

Target URL: https://httpbin.org

Scan Date: 2026-02-05T21:56:48.173845+00:00

Status: completed

Pages Analyzed: 2

Vulnerabilities Found: 15

Vulnerability Summary by Severity

Severity	Count
Critical	0
High	3
Medium	4
Low	8
Info	0

OWASP Top 10 2025 Coverage

OWASP ID	Category	Findings
A01	Broken Access Control	1
A02	Security Misconfiguration	14
A03	Software Supply Chain Failures	0
A04	Cryptographic Failures	0
A05	Injection	0
A06	Insecure Design	0
A07	Authentication Failures	0
A08	Software or Data Integrity Failures	0
A09	Logging & Alerting Failures	0
A10	Mishandling of Exceptional Conditions	0

Detailed Vulnerability Findings

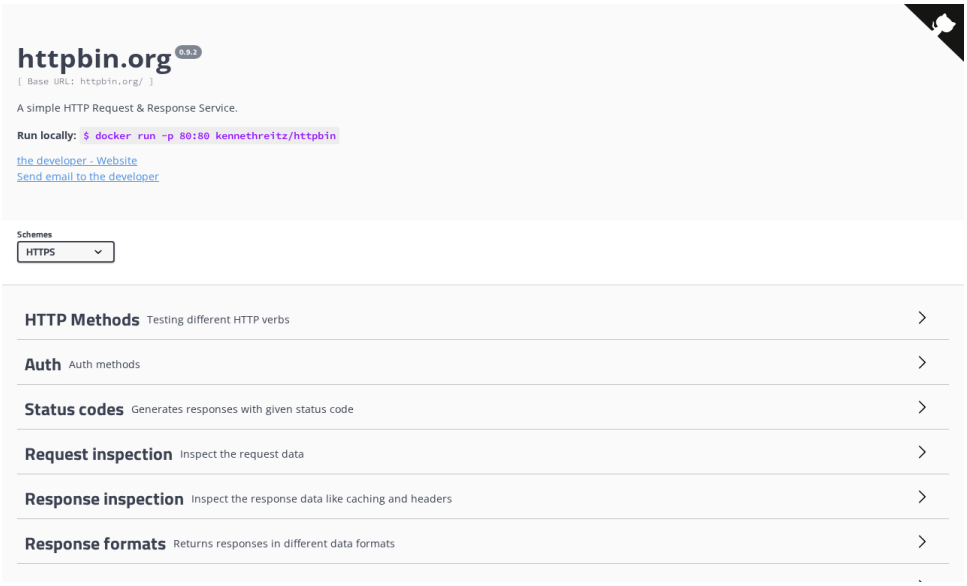
Testing Tools Used

Tool Name	Test Type
CORS Policy Analyzer (HTTPX)	DAST
HTML Form Analyzer (BeautifulSoup)	SAST
HTTP Header Analyzer (HTTPX)	DAST

1. [High] CORS Origin Reflection with Credentials

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org
Description: CORS reflects origin and allows credentials
Detection Tool: CORS Policy Analyzer (HTTPX)
Test Type: DAST
Evidence: Origin reflected: https://evil.com, Credentials: true
Remediation: Do not reflect arbitrary origins with credentials enabled

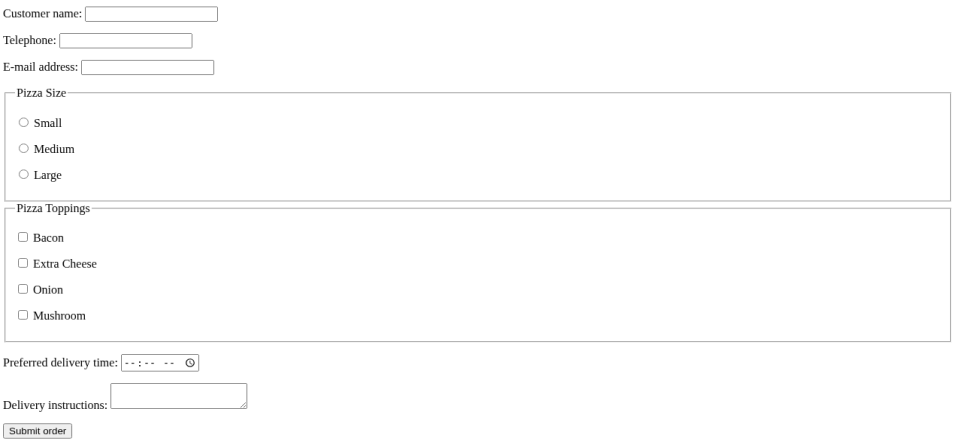
Screenshot Evidence:



2. [High] Missing CSRF Protection

OWASP Category: A01 - Broken Access Control
URL: https://httpbin.org/forms/post
Description: Form is missing CSRF token protection
Detection Tool: HTML Form Analyzer (BeautifulSoup)
Test Type: SAST
Evidence: Form action: /post, Method: post
Remediation: Implement CSRF tokens in all forms

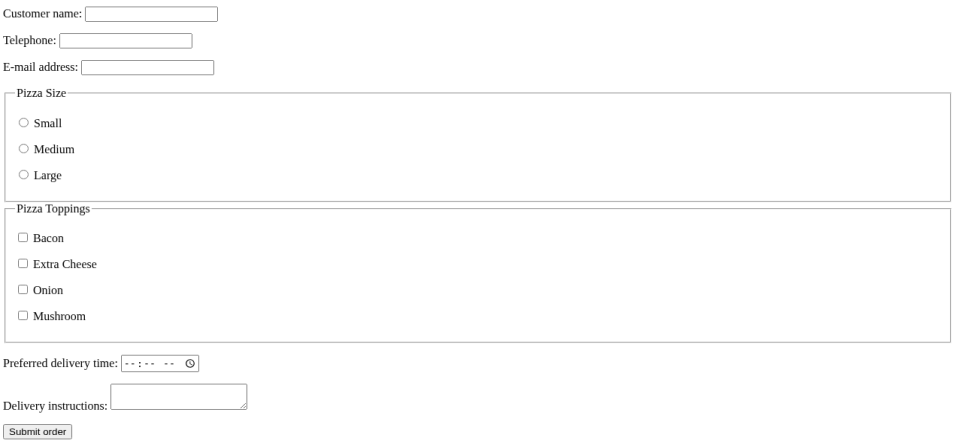
Screenshot Evidence:



3. [High] CORS Origin Reflection with Credentials

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/forms/post
Description: CORS reflects origin and allows credentials
Detection Tool: CORS Policy Analyzer (HTTPX)
Test Type: DAST
Evidence: Origin reflected: https://evil.com, Credentials: true
Remediation: Do not reflect arbitrary origins with credentials enabled

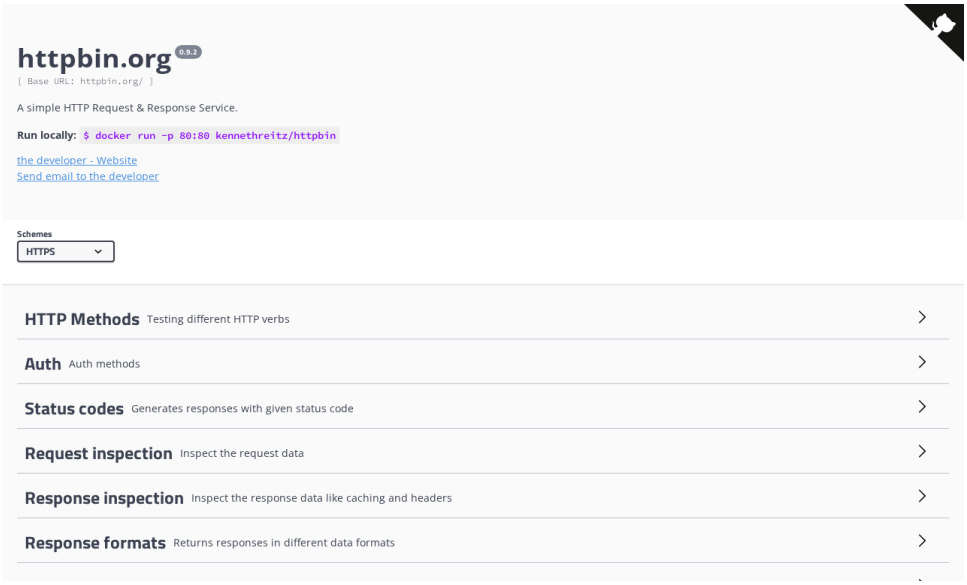
Screenshot Evidence:



4. [Medium] Missing Security Header: Strict-Transport-Security

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org
Description: HSTS not configured - enables man-in-the-middle attacks
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'Strict-Transport-Security' not found in response
Remediation: Add the Strict-Transport-Security header to your server configuration

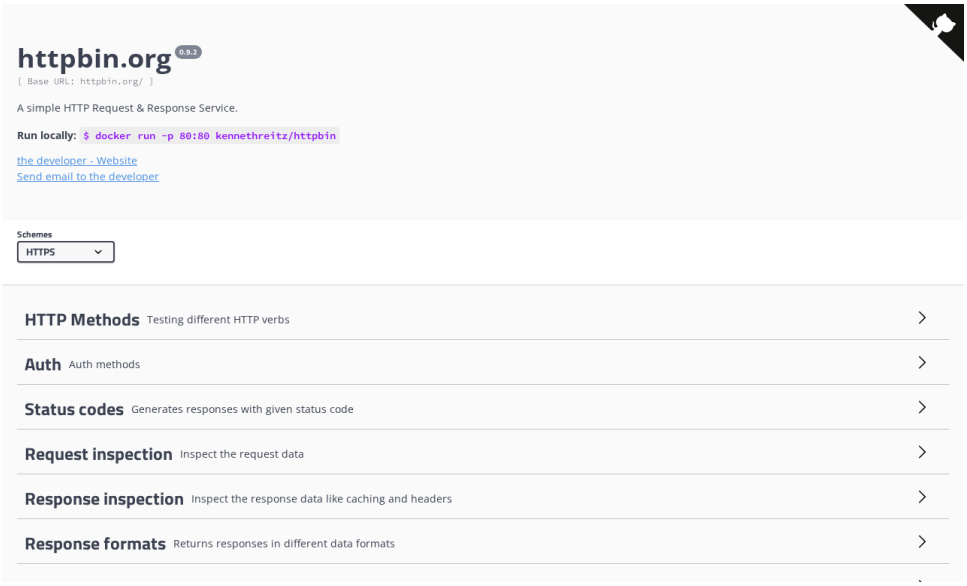
Screenshot Evidence:



5. [Medium] Missing Security Header: Content-Security-Policy

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org
Description: Missing CSP - increases XSS attack risk
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'Content-Security-Policy' not found in response
Remediation: Add the Content-Security-Policy header to your server configuration

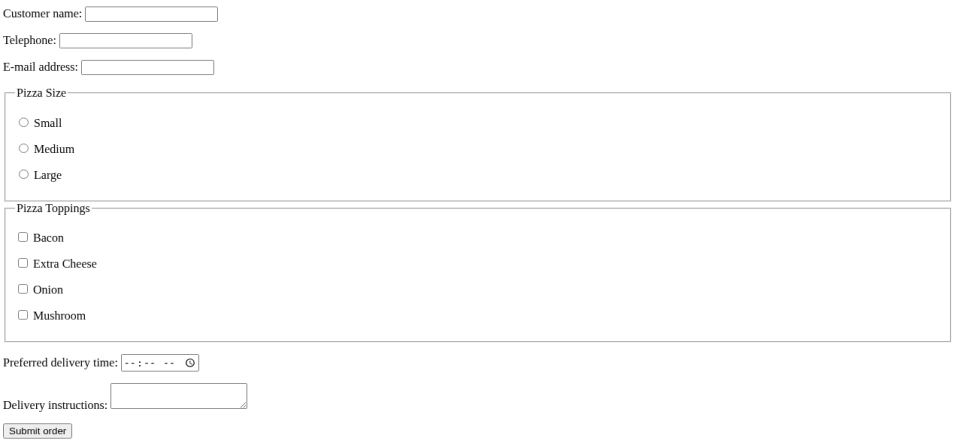
Screenshot Evidence:



6. [Medium] Missing Security Header: Strict-Transport-Security

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/forms/post
Description: HSTS not configured - enables man-in-the-middle attacks
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'Strict-Transport-Security' not found in response
Remediation: Add the Strict-Transport-Security header to your server configuration

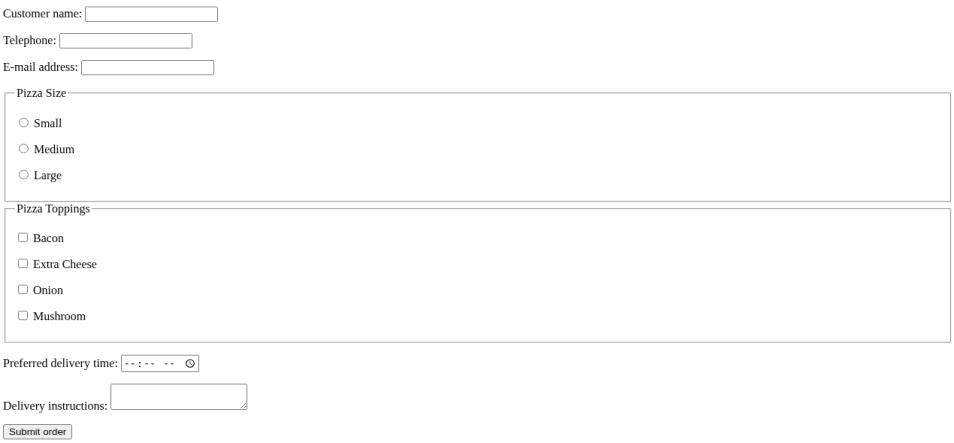
Screenshot Evidence:



7. [Medium] Missing Security Header: Content-Security-Policy

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/forms/post
Description: Missing CSP - increases XSS attack risk
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'Content-Security-Policy' not found in response
Remediation: Add the Content-Security-Policy header to your server configuration

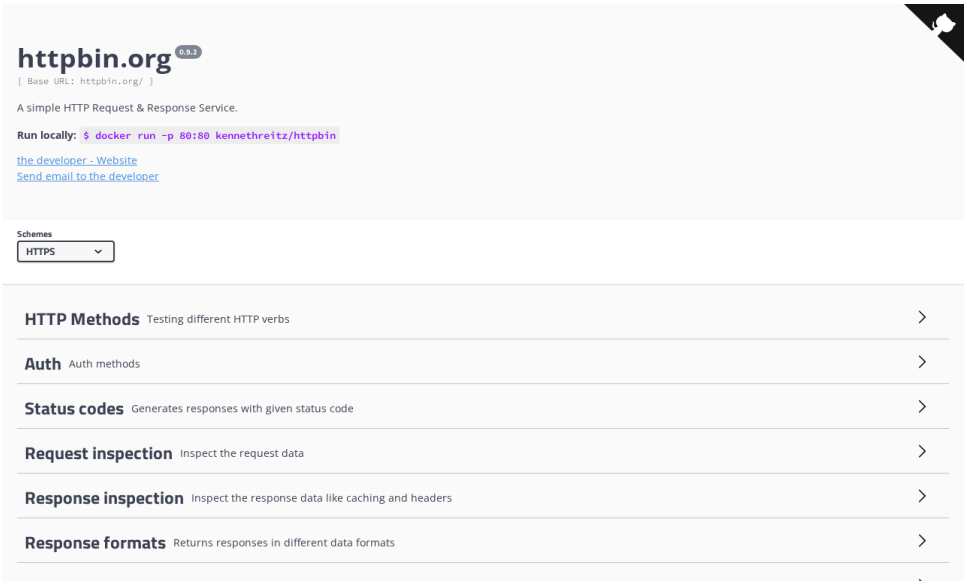
Screenshot Evidence:



8. [Low] Missing Security Header: X-Content-Type-Options

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org
Description: Missing X-Content-Type-Options - enables MIME-type sniffing attacks
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'X-Content-Type-Options' not found in response
Remediation: Add the X-Content-Type-Options header to your server configuration

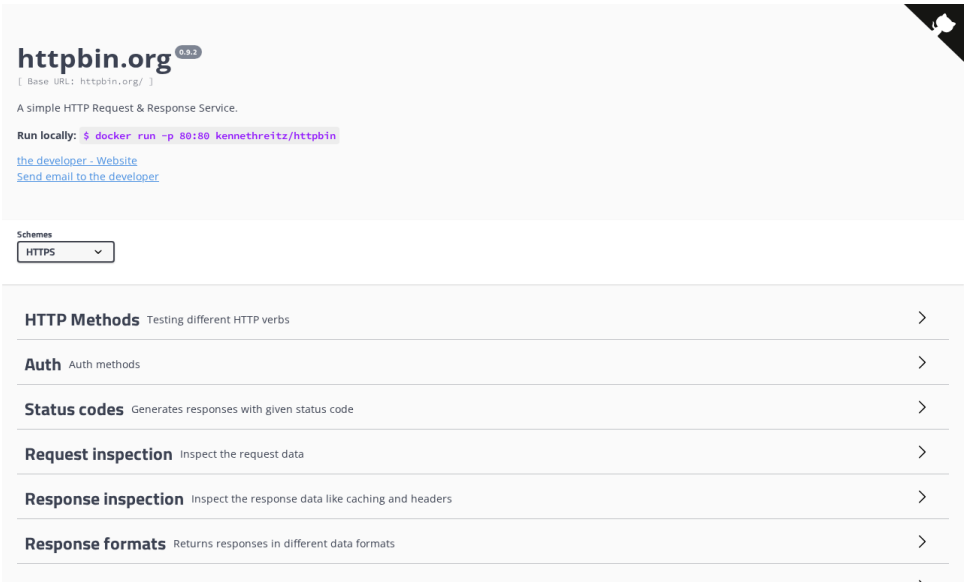
Screenshot Evidence:



9. [Low] Missing Security Header: X-Frame-Options

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org
Description: Missing X-Frame-Options - enables clickjacking attacks
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'X-Frame-Options' not found in response
Remediation: Add the X-Frame-Options header to your server configuration

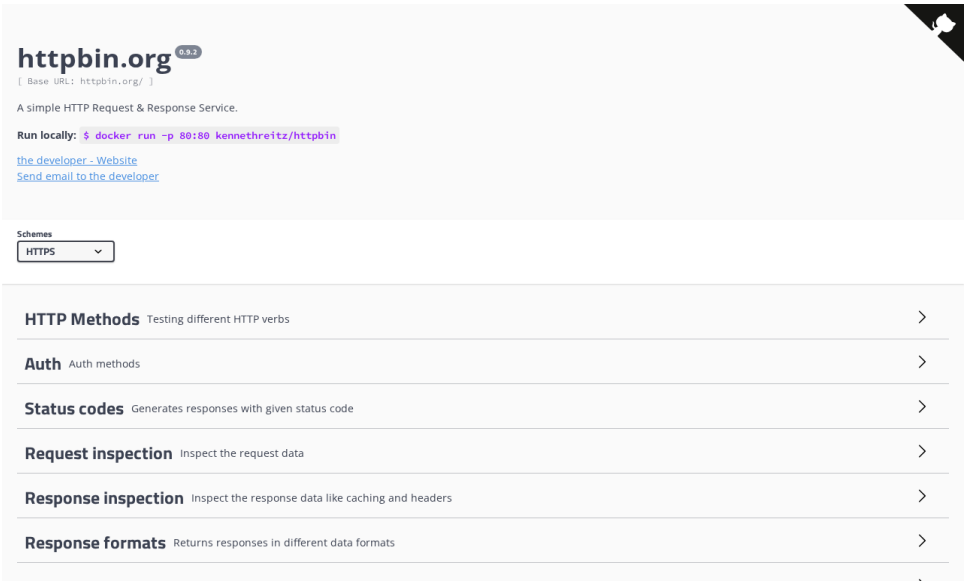
Screenshot Evidence:



10. [Low] Missing Security Header: X-XSS-Protection

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org
Description: Missing X-XSS-Protection header
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'X-XSS-Protection' not found in response
Remediation: Add the X-XSS-Protection header to your server configuration

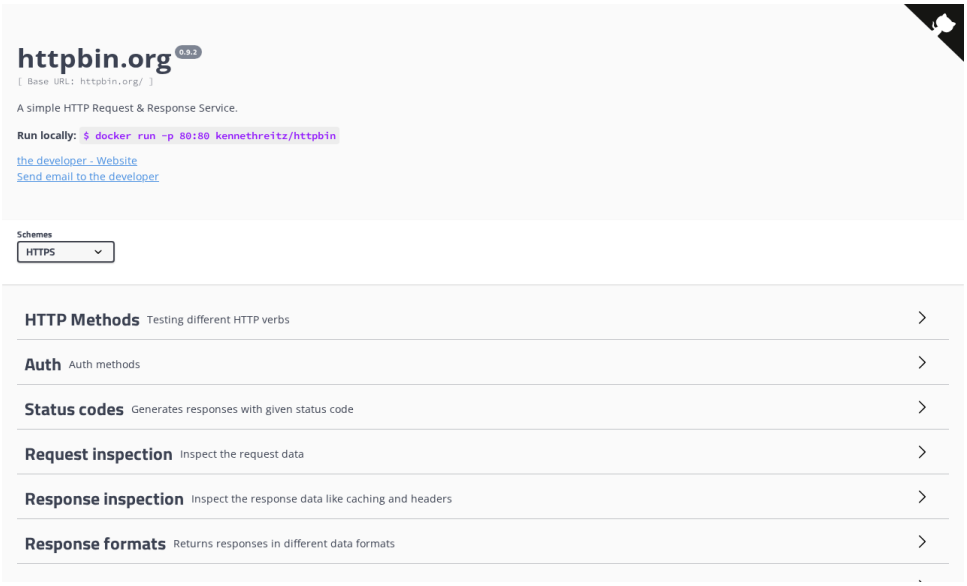
Screenshot Evidence:



11. [Low] Missing Security Header: Referrer-Policy

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org
Description: Missing Referrer-Policy - may leak sensitive URL information
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'Referrer-Policy' not found in response
Remediation: Add the Referrer-Policy header to your server configuration

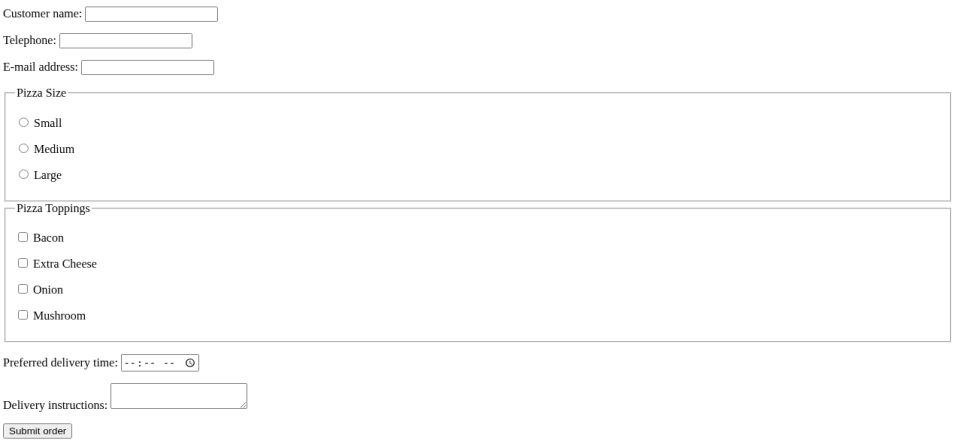
Screenshot Evidence:



12. [Low] Missing Security Header: X-Content-Type-Options

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/forms/post
Description: Missing X-Content-Type-Options - enables MIME-type sniffing attacks
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'X-Content-Type-Options' not found in response
Remediation: Add the X-Content-Type-Options header to your server configuration

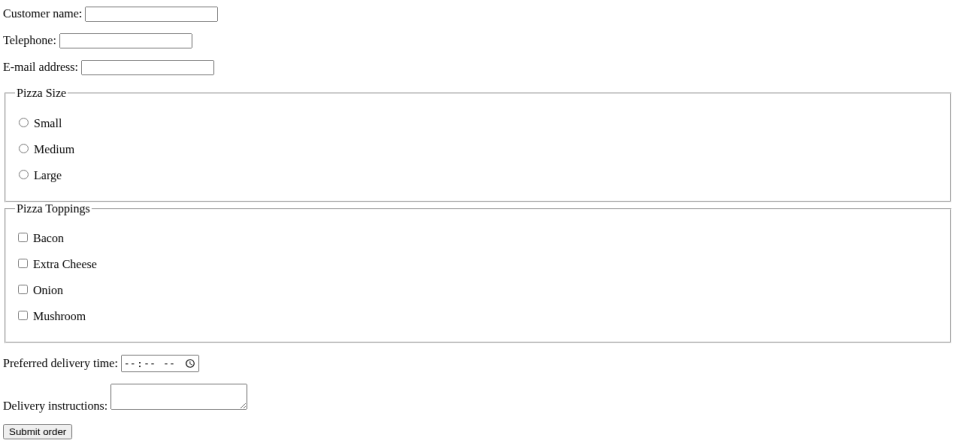
Screenshot Evidence:



13. [Low] Missing Security Header: X-Frame-Options

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/forms/post
Description: Missing X-Frame-Options - enables clickjacking attacks
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'X-Frame-Options' not found in response
Remediation: Add the X-Frame-Options header to your server configuration

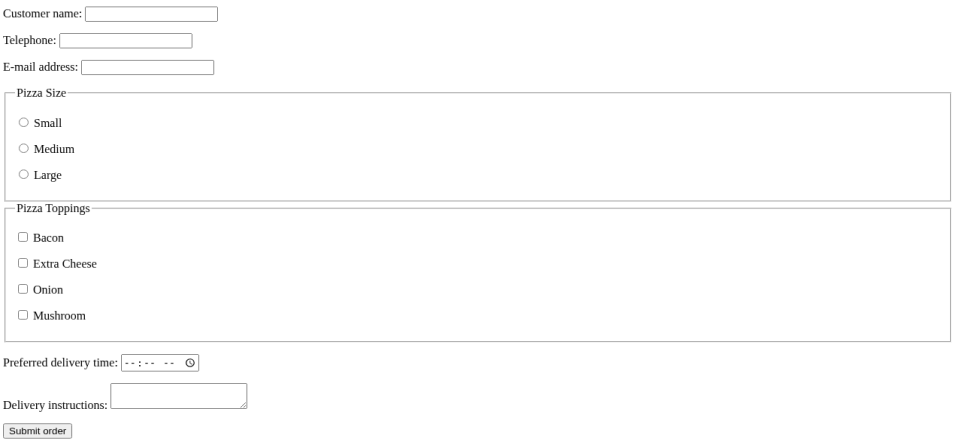
Screenshot Evidence:



14. [Low] Missing Security Header: X-XSS-Protection

OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/forms/post
Description: Missing X-XSS-Protection header
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'X-XSS-Protection' not found in response
Remediation: Add the X-XSS-Protection header to your server configuration

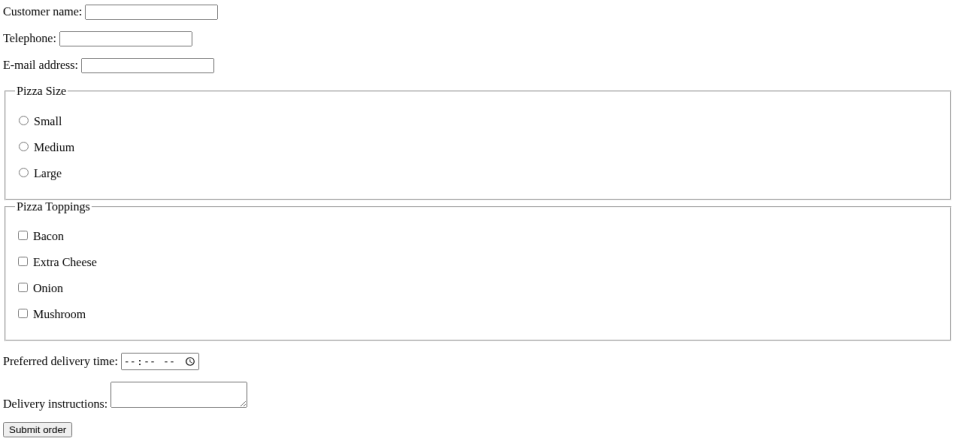
Screenshot Evidence:



15. [Low] Missing Security Header: Referrer-Policy

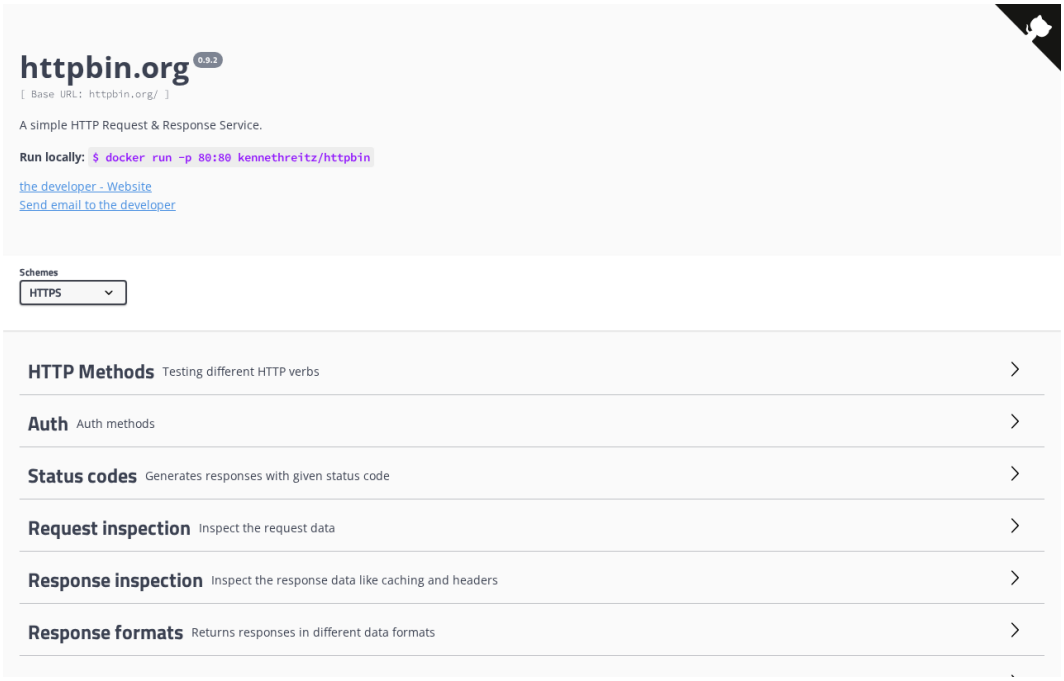
OWASP Category: A02 - Security Misconfiguration
URL: https://httpbin.org/forms/post
Description: Missing Referrer-Policy - may leak sensitive URL information
Detection Tool: HTTP Header Analyzer (HTTPX)
Test Type: DAST
Evidence: Header 'Referrer-Policy' not found in response
Remediation: Add the Referrer-Policy header to your server configuration

Screenshot Evidence:

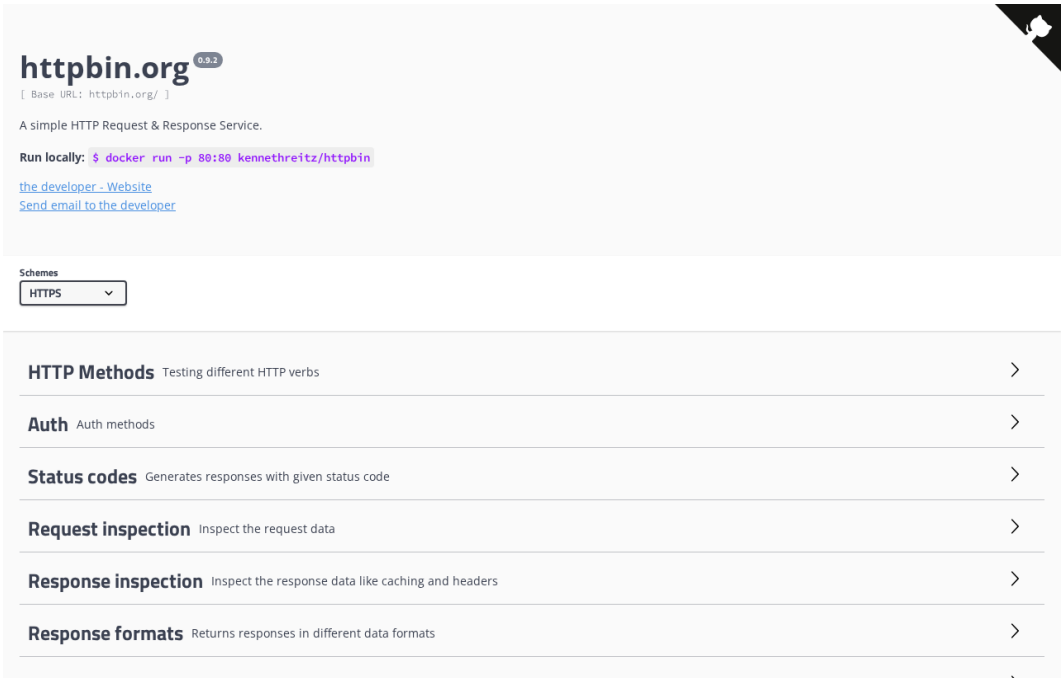


Target Application Screenshots

Screenshot 1: main_page.png



Screenshot 2: vuln_page_0.png



Screenshot 3: vuln_page_1.png

Customer name:

Telephone:

E-mail address:

Pizza Size

- Small
- Medium
- Large

Pizza Toppings

- Bacon
- Extra Cheese
- Onion
- Mushroom

Preferred delivery time:

Delivery instructions:

Submit order